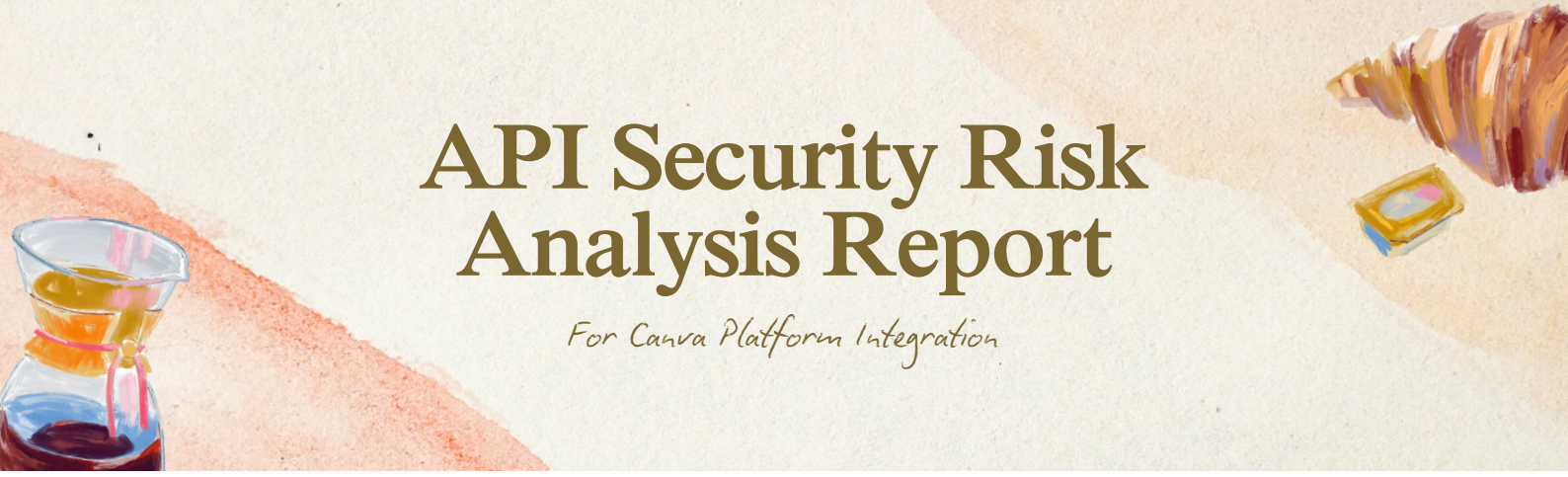




API Security Risk Analysis Report

For Canva Platform Integration

Document Type: Strategic API Security Assessment

Target Architecture: Canva Ecosystem App

Integration Integration Layers

**Evaluated Framework: Canvas App-to-Platform
Transactional & Content APIs**

Date: June 22, 2026

**Prepared By: Senior Application Security & SaaS
Consultant**

Executive Summary

A structural security analysis was performed on the integration design of the Canva API ecosystem. The evaluation scrutinized the architecture behind session-state boundaries, transactional design states (such as drafting versus committing modifications), asset lifecycle boundaries, and multi-tenant isolation parameters. While the core platform utilizes sophisticated transaction token isolation, specific edge configurations in downstream client apps present integration risks. This report details these architectural liabilities mapped to the OWASP API Security Top 10 and details standard defensive remediation vectors.

Risk Findings & Analysis Matrix

Finding ID	Vulnerability Title	OWASP API 2023 Match	Severity
CAN-SEC-01	Transaction Session Hijacking / Stale State Commit	API1:2023 Broken Object Level Authorization	High
CAN-SEC-02	Unrestricted Multi-Page Media Injection	API4:2023 Unrestricted Resource Consumption	Medium
CAN-SEC-03	Scope Creep via Over-Privileged OAuth Asset Tokens	API5:2023 Broken Function Level Authorization	Medium

Detailed Vulnerability Breakdown

CAN-SEC-01: Transaction Session Hijacking / Stale State Commit Risks

Severity: High

Architectural Component: & state sequence

Technical Observation: The integration uses a clear state workflow where edits are kept as temporary drafts tied to a specific before they are permanently written to the design. However, if a client application caches this globally or fails to strictly validate user permissions during cross-origin calls between initialization and completion, a malicious actor within the same workspace could theoretically guess or intercept the identifier. They could then complete the commit process prematurely or alter the payload contents.

Business Impact: Attackers can hijack active document editing sessions to insert unauthorized imagery, alter corporate marketing collateral maliciously, or tamper with financial graphics before a user finalize their design. This directly compromises corporate identity and data integrity.

Remediation Steps:

- Cryptographic Sealing:** Ensure that the is a high-entropy, short-lived token bound strictly to the cryptographically verified user session that initiated it.
- Double-Ended Authorization:** Re-validate the caller's OAuth tokens and user permissions at the precise moment is invoked, matching them against the session that called .

CAN-SEC-02: Unrestricted Multi-Page Media Injection

Severity: Medium

Architectural Component: (Mass Payload Arrays)

Technical Observation: The array allows multiple changes to be batched together across different pages at the same time. If a client app doesn't enforce strict array size limits before forwarding

payloads to backend web services, an integration layer could face severe memory consumption spikes when handling oversized batches. This occurs when large amounts of heavy media elements are injected onto multiple responsive pages simultaneously.

Business Impact: Malicious workspace users or compromised integrated apps can send bloated transaction payloads. This can freeze layout rendering engines, cause timeouts, and degrade performance for all other users working within the shared enterprise tenancy.

Remediation Steps:

- **Array Payload Bounds:** Enforce a strict threshold limit on the maximum number of structural operations (e.g., maximum 50 canvas mutations) permitted per individual call to .
- **Asynchronous Layout Throttling:** Process heavy layout updates on responsive design pages inside an isolated queue workers pool rather than synchronously blocking main thread execution.

CAN-SEC-03: Scope Creep via Over-Privileged OAuth Asset Tokens

Severity: Medium

Architectural Component: & permission matrix

Technical Observation: When cross-functional third-party modules or connectors pull assets or look up brand guidelines, the integration often defaults to broad team scopes. This can grant apps read access to the entire design directory or all brand kits, even when the specific user task only requires access to a single template asset.

Business Impact: If a malicious or compromised third-party app gains broad team-wide read scopes, it could lead to large-scale data harvesting. Attackers could steal unreleased product designs, proprietary corporate layouts, or sensitive strategic roadmaps managed across different teams.

Remediation Steps:

- **Context-Driven Scoping:** Enforce contextual scoping flags on integration routes. If an app only needs to populate a template, restrict its downstream calls strictly to that singular .
- **Ephemeral Context Tokens:** Issue temporary runtime tokens for design access that expire immediately after the transaction session is completed or closed.

Conclusion & Strategic Next Steps

The transactional architecture provides a solid security foundation for collaborative multi-tenant applications. To prevent perimeter vulnerabilities, developers building on this API layer must treat the lifecycle of values with the same cryptographic rigor as master authentication sessions. Implement validation lookups on all batch commands to ensure a secure integration experience.